Data Flow Diagrams (DFD) & Decision Specifications

Academic Grievance, No-Dues & Clearance Automation Engine

Institution: Punjab Engineering College (Deemed to be University), Chandigarh
Course: Software Engineering
Supervisor: Dr. Rajesh Bhatia
Authors: Raghav Bhardwaj & Karan Jain (B.Tech CSE, Batch 2022–2026)
Document Scope: Level 0 (Context), Level 1 (Decomposition), Decision Tables, Decision Trees, and Detailed Process Explanations

---

Table of Contents

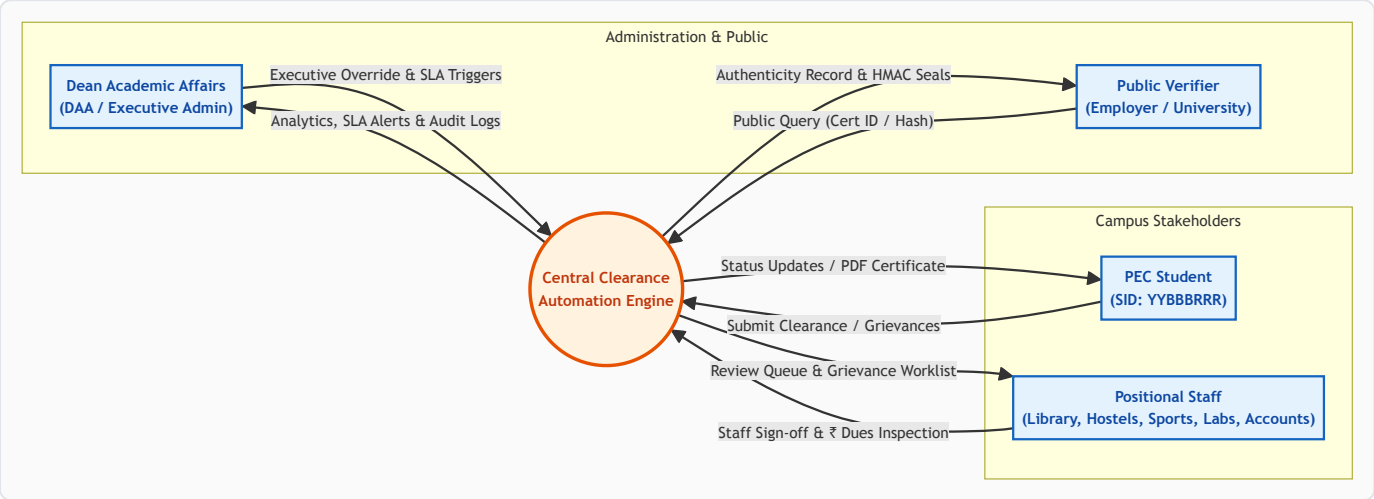
1. DFD Level 0: Context Analysis Diagram
    - Level 0 Context Diagram
    - Architectural Explanation & External Entities
    - Boundary Data Flows Summary
2. DFD Level 1: System Decomposition Diagram
    - Level 1 System Data Flow Diagram
    - Functional Subsystems Explanation (Processes 1 to 6)
    - Persistent Data Stores Explanation (DS-1 to DS-6)
3. Clearance Gating: Decision Table 1 & Decision Trees 1 & 2
    - Decision Table 1: Multi-Gate Clearance Pipeline Matrix
    - Decision Table 1 Explanation (Chain of Responsibility & Barriers)
    - Decision Tree 1: Clearance Gating & Barrier Enforcement
    - Decision Tree 1 Explanation
    - Decision Tree 2: Departmental Liability Assessment & HMAC Signing
    - Decision Tree 2 Explanation
4. Grievance Redressal: Decision Table 2 & Decision Tree 3
    - Decision Table 2: Priority SLA Deadline & Escalation Matrix
    - Decision Table 2 Explanation (Dynamic SLA Timers & Rules)
    - Decision Tree 3: Grievance Arbitration & Escalation
    - Decision Tree 3 Explanation
5. Role-Based Access Control: Decision Table 3 & Decision Tree 4
    - Decision Table 3: RBAC Authorization Matrix
    - Decision Table 3 Explanation (Security Scopes & Gate Enforcement)
    - Decision Tree 4: API Gateway Authentication & Authorization
    - Decision Tree 4 Explanation

---

1. DFD Level 0: Context Analysis Diagram

The **Level 0 Context Diagram** defines the primary environmental boundary of the PEC Clearance Automation Engine, mapping all interactions between campus stakeholders and the central automated processing engine.

Level 0 Context Diagram



Architectural Explanation & External Entities

The Context Diagram encapsulates the entire institutional software system within a single high-level transformation bubble, isolating internal operations from four external entities:

1. **PEC Student (`Student`):**
   - **Identity:** Identified by an immutable 8-digit PEC Student Identifier (`YYBBBRRR`, e.g., `22103042`).
   - **Function:** Applies for clearance at degree completion or milestone exit, monitors real-time progress across all 5 departmental facilities, reviews itemized outstanding liabilities in Indian Rupees (`₹`), files grievance appeals against disputed charges, and retrieves digitally signed vector PDF certificates.
2. **Positional Department Staff (`Staff`):**
   - **Identity:** Positional signatories representing Dr. B.R. Ambedkar Central Library, PEC Hostels, Gymkhana (Sports), Department Computing/Hardware Labs, and the Accounts Branch.
   - **Function:** Authenticates under facility role scopes, inspects physical asset returns, records itemized liabilities (`due_amount` in INR), issues digital approvals sealed with keyed HMAC-SHA256 tokens, and arbitrates student grievance tickets.
3. **Dean Academic Affairs (`Admin` / DAA):**
   - **Identity:** Executive academic oversight persona.
   - **Function:** Monitors campus-wide clearance efficiency and department bottleneck latency, receives high-priority alerts for breached Service Level Agreements (SLAs), and possesses executive authority to override clearance rejections with mandatory audit justification.
4. **Public Certificate Verifier (`Verifier`):**
   - **Identity:** External employers, background screening agencies, and international universities.
   - **Function:** Performs tokenless, zero-login cryptographic verification of issued certificates using either the unique Certificate ID (`PEC-CLR-YYYY-XXXXX`) or the 64-character SHA-256 public hash digest.

Boundary Data Flows Summary

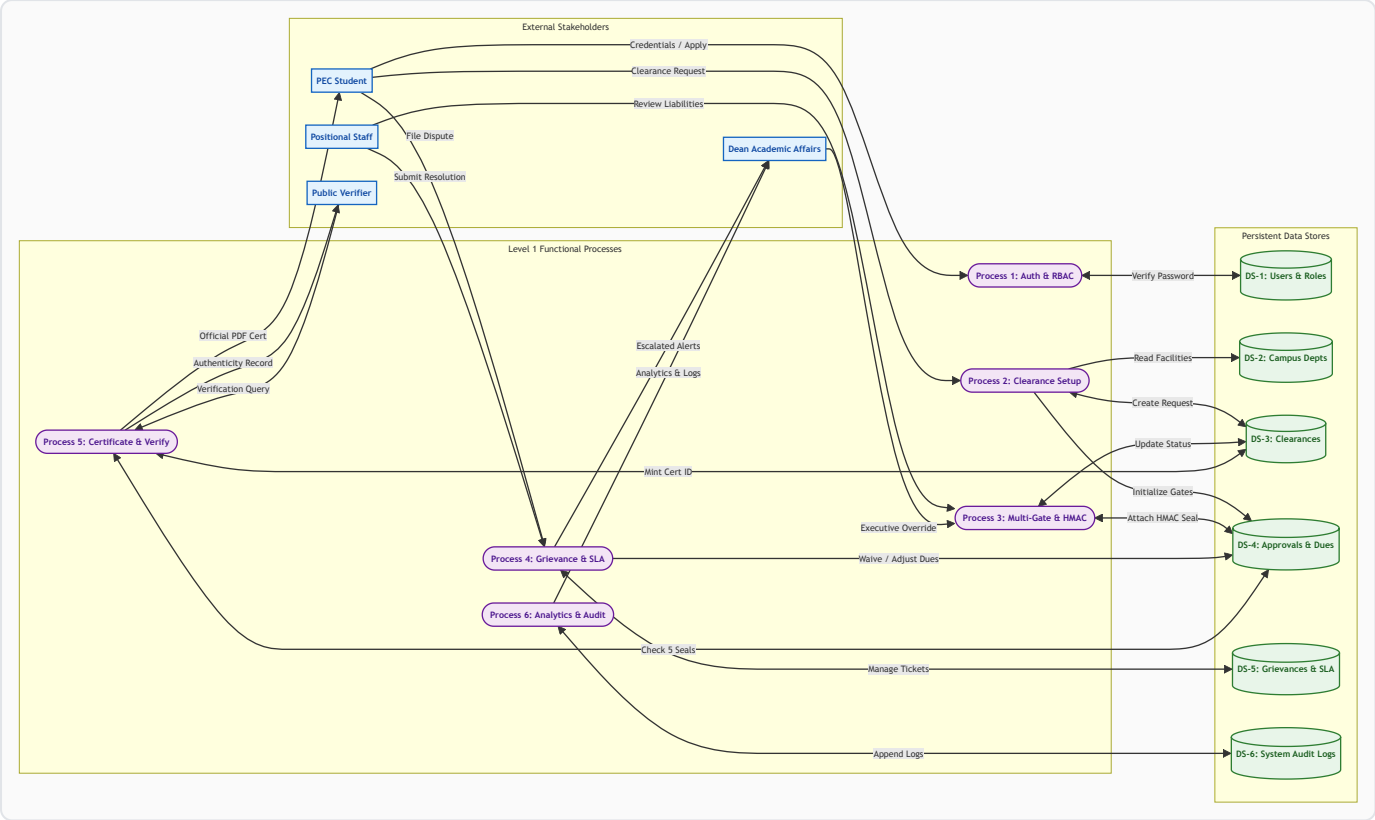
- **Inbound Data Flows:**
  - `Clearance Application`: Student SID, academic year, semester, and clearance justification.
  - `Grievance Submission`: Department target, subject, dispute narrative, and priority tier (`LOW`, `MEDIUM`, `HIGH`, `CRITICAL`).
  - `Liability Inspection & Sign-off`: Approval decision (`APPROVED` or `REJECTED`), itemized dues in INR (`₹`), and reviewer commentary.
  - `Executive Override Order`: Clearance ID, department code, and mandatory DAA justification.
  - `Public Verification Query`: Certificate ID string or SHA-256 hash digest.
- **Outbound Data Flows:**
  - `Live Pipeline Status`: Multi-gate progress status and itemized dues across all facilities.
  - `Tamper-Proof PDF Certificate`: Printable vector PDF embedded with institutional seals and SHA-256 digest.
  - `Department Review Queue`: Filtered list of pending student clearance records restricted to staff's facility.
  - `SLA Breach Alerts`: Real-time administrative notifications for overdue grievances.
  - `Authenticity Verification Record`: JSON payload confirming validity, student metadata, and 5 departmental HMAC seals.

---

2. DFD Level 1: System Decomposition Diagram

The **Level 1 System Data Flow Diagram** decomposes the top-level system into six dedicated, single-responsibility operational subsystems (`Process 1` through `Process 6`), interacting directly with six persistent relational data stores (`DS-1` through `DS-6`).

Level 1 System Data Flow Diagram



Functional Subsystems Explanation (Processes 1 to 6)

1. **Process 1: User Authentication & Role Authorization (`auth.py`, `security.py`)**
   - **Function:** Authenticates inbound users against Bcrypt-salted password hashes, validates PEC institutional domains (`@pec.edu.in`), issues signed cryptographic JSON Web Tokens (JWT), and checks role claims (`STUDENT`, `STAFF`, `ADMIN`) to protect API routes.
   - **Inputs:** Raw email and plaintext password from Student, Staff, or Admin; stored hashes from `DS-1`.
   - **Outputs:** Signed Bearer JWT access tokens with encoded identity claims (`sub`, `role`, `exp`).
2. **Process 2: Clearance Application & Gating Setup (`clearance.py`)**
   - **Function:** Enforces the institutional single-active-request invariant, captures student degree milestone details, provisions the master clearance record in `DS-3`, and initializes 5 departmental approval records in `DS-4` (Gate 1 facilities set to `PENDING`; Gates 2 & 3 set to `WAITING_PREREQUISITE`).
   - **Inputs:** Clearance application packet from Student; active facility records from `DS-2`.
   - **Outputs:** Master clearance record in `DS-3`; 5 initialized approval rows in `DS-4`; audit event to `DS-6`.
3. **Process 3: Departmental Review, Chain of Responsibility & HMAC Signing (`chain_of_responsibility.py`)**
   - **Function:** Orchestrates the multi-signatory clearance pipeline using the behavioral Chain of Responsibility design pattern. Enforces parallel reviews at Gate 1, sequential dependency barriers at Gate 2 and Gate 3, calculates keyed HMAC-SHA256 digital seals upon approval, handles DAA executive overrides, and mutates master clearance status.
   - **Inputs:** Staff decisions (`APPROVED` / `REJECTED`), itemized dues in INR (`₹`), DAA override commands; current approval states from `DS-4`.
   - **Outputs:** Cryptographic HMAC signature seals attached to `DS-4`; unlocked downstream gates; master status update in `DS-3`.

4. **Process 4: Grievance Redressal & SLA Escalation Engine (`grievance.py`)**
    - **Function:** Provides an institutional dispute mechanism for students contesting incorrect dues or missing records. Automatically assigns dynamic SLA deadlines based on ticket priority (`CRITICAL`: 4h, `HIGH`: 12h, `MEDIUM`: 24h, `LOW`: 48h). Scans for expired tickets and triggers automated escalation banners directly to the DAA dashboard.
    - **Inputs:** Student grievance filings; staff resolution decisions; periodic SLA scan pulses.
    - **Outputs:** Grievance records in `DS-5`; adjusted/waived dues in `DS-4`; real-time SLA breach alerts to Admin.
5. **Process 5: Certificate Minting, PDF Rendering & Verification (`certificate.py`, `pdf_generator.py`)**
    - **Function:** Validates that all 5 departmental facilities have recorded `APPROVED` statuses with valid cryptographic HMAC seals. Unlocks the release of the student's ₹10,000 Caution Money refund, mints a permanent Certificate ID (`PEC-CLR-YYYY-XXXXX`), calculates a 64-character SHA-256 verification hash, generates an official vector PDF with letterhead, and serves tokenless public verifications.
    - **Inputs:** 5 valid approval records from `DS-4`; clearance record from `DS-3`; public verification queries.
    - **Outputs:** Minted certificate details in `DS-3`; printable binary PDF to Student; verification JSON to Verifier.
6. **Process 6: Institutional Administration, Analytics & Audit (`admin.py`)**
    - **Function:** Computes institutional clearance metrics (overall completion rates, average department review latency, clearance bottlenecks), and maintains an immutable append-only system audit log tracking every security and operational event.
    - **Inputs:** Internal lifecycle event signals; aggregate queries across `DS-3`, `DS-4`, and `DS-5`.
    - **Outputs:** Real-time campus analytics payloads and append-only audit entries in `DS-6`.

Persistent Data Stores Explanation (DS-1 to DS-6)

- **`DS-1: Users & Personas` (`users` table):** Stores user credentials, salted Bcrypt password hashes, personas (`STUDENT`, `STAFF`, `ADMIN`), student roll numbers (SIDs), and staff department assignments.
- **`DS-2: Campus Departments` (`departments` table):** Institutional configuration of the 5 facilities (Library, Hostels, Sports, Labs, Accounts), gate classifications (Gate 1, 2, or 3), and positional head titles.
- **`DS-3: Clearance Requests` (`clearance_requests` table):** Master clearance records storing student references, academic session, overall status (`PENDING`, `APPROVED`, `REJECTED`), certificate ID, and public SHA-256 hash digest.
- **`DS-4: Department Approvals & HMAC Seals` (`department_approvals` table):** Operational approval rows containing review status (`WAITING_PREREQUISITE`, `PENDING`, `APPROVED`, `REJECTED`), itemized dues in INR (`due_amount`), reviewer remarks, and keyed HMAC-SHA256 signature seals.
- **`DS-5: Grievances & SLA Timers` (`grievances` table):** Dispute tickets holding priority classification, computed absolute SLA expiration timestamps, escalation flags (`is_escalated`), staff responses, and resolution timestamps.
- **`DS-6: System Audit Logs` (`audit_logs` table):** Append-only audit trail capturing actor ID, actor role, immutable action verb, affected entity ID, textual details, and microsecond UTC timestamps.

---

3. Clearance Gating: Decision Table 1 & Decision Trees 1 & 2

Decision Table 1: Multi-Gate Clearance Pipeline Matrix

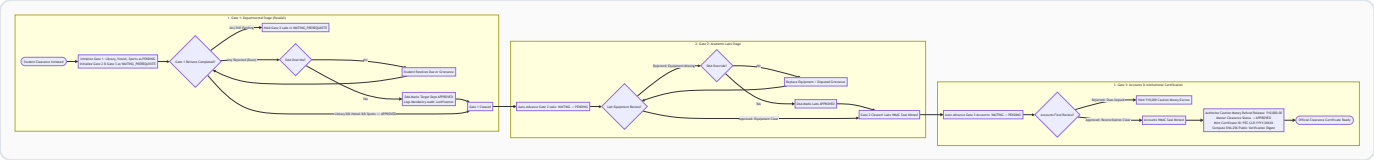
This decision table formalizes the state transition and gating barrier rules enforced by the **Chain of Responsibility** engine (`Process 3`):

Rule ID	Gate 1 Status (Lib / Host / Sport)	Gate 2 Status (Dept Labs)	Gate 3 Status (Accounts)	DAA Override?	Action Target & Enforced State Transition
R-101	All `PENDING`	`WAITING`	`WAITING`	No	Allow concurrent Gate 1 reviews; mutate to `APPROVED` or `REJECTED` ; mint HMAC seal on approval.
R-102	Any `PENDING` / `REJECTED`	`WAITING`	`WAITING`	No	**BLOCK GATE 2 WITH HTTP 400:** Reject review attempt; Gate 1 facilities incomplete or disputed.
R-103	Any `REJECTED` (Dues > ₹0)	`WAITING`	`WAITING`	No	**REJECT MASTER STATUS:** Set overall request to `REJECTED` ; prompt student to settle dues or file grievance.
R-104	All `APPROVED`	`WAITING`	`WAITING`	No	**AUTO-UNLOCK GATE 2:** Automatically advance Gate 2 (Dept Labs) from `WAITING` to `PENDING` .
R-105	All `APPROVED`	`PENDING`	`WAITING`	No	Allow HOD Labs review; inspect lab kits; if clear, mint HMAC seal and set status to `APPROVED` .
R-106	All `APPROVED`	`APPROVED`	`WAITING`	No	**AUTO-UNLOCK GATE 3:** Automatically advance Gate 3 (Accounts) from `WAITING` to `PENDING` .
R-107	All `APPROVED`	`APPROVED`	`PENDING`	No	Allow Accounts review; reconcile dues; authorize release of ₹10,000 Caution Money deposit refund.
R-108	All `APPROVED`	`APPROVED`	`APPROVED`	No	**MASTER CLEARANCE GRANTED:** Mutate master status to `APPROVED` ; mint Certificate ID & SHA-256 Digest.
R-109	Any `REJECTED`	Any	Any	**Yes (DAA)**	**EXECUTIVE OVERRIDE:** Mark target department `APPROVED` ; clear dues; log `ADMIN_OVERRIDE` in `DS-6` .

Decision Table 1 Explanation (Chain of Responsibility & Barriers)

1. **Gate 1 Parallel Independence (Rule R-101):** The three Gate 1 departments (Central Library, Hostels, Sports) operate concurrently. A rejection or delay in one does not block staff members in the other two from inspecting assets or recording sign-offs.
2. **Sequential Dependency Barriers (Rules R-102 & R-106):** Gate 2 (Department Labs) cannot be reviewed until all three Gate 1 facilities are `APPROVED` . Any attempt by lab staff to sign off prematurely is rejected with HTTP `400 Bad Request` . Similarly, Gate 3 (Accounts) cannot be accessed until Gate 2 is fully cleared.
3. **Automated Pipeline Advancement (Rules R-104 & R-106):** The system dynamically scans prerequisites upon every sign-off. When the final Gate 1 facility is approved, Gate 2 automatically transitions from `WAITING_PREREQUISITE` to `PENDING` . When Gate 2 is approved, Gate 3 automatically unlocks.
4. **Caution Money Disbursement & Master Certification (Rules R-107 & R-108):** Accounts Branch review triggers financial reconciliation. Once Gate 3 is approved, the institutional Caution Money escrow deposit (₹10,000.00) is marked for release, and the master request status becomes `APPROVED` .
5. **Executive Override Powers (Rule R-109):** The Dean Academic Affairs retains statutory authority to override departmental rejections (e.g., in cases of administrative error or approved waivers), immediately setting the target department to `APPROVED` and recording a mandatory audit trail entry in `DS-6` .

Decision Tree 1: Clearance Gating & Barrier Enforcement

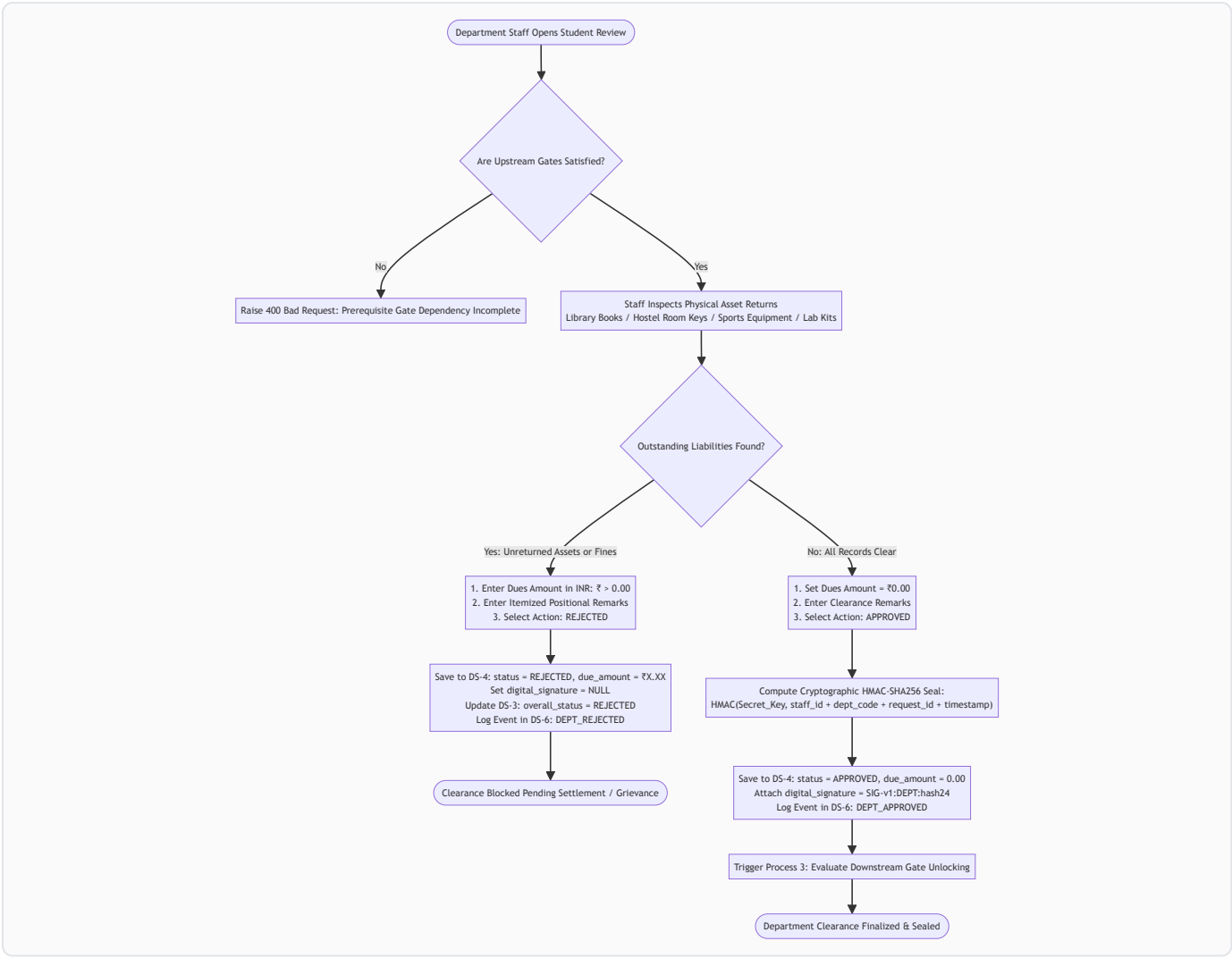


Decision Tree 1 Explanation

Decision Tree 1 models the hierarchical execution flow across the three clearance gates:

- **Phase 1 (Gate 1 Execution):** Initializes the three non-academic facilities concurrently. If any liability is found, the clearance halts with status `REJECTED`, prompting the student to pay or file a grievance. Only when all three facilities record `APPROVED` (or receive DAA override) does the pipeline advance.
- **Phase 2 (Gate 2 Execution):** The automated engine advances Gate 2 from `WAITING` to `PENDING`. Academic computing/hardware labs verify asset returns. Approval seals the department record with an HMAC-SHA256 signature; rejection blocks further progress.
- **Phase 3 (Gate 3 Execution):** Accounts Branch reconciles tuition, hostel, and fee accounts. Once approved, the ₹10,000 Caution Money refund is authorized, the master status becomes `APPROVED`, and the system generates the unique Certificate ID and public verification digest.

Decision Tree 2: Departmental Liability Assessment & HMAC Signing



Decision Tree 2 Explanation

Decision Tree 2 details the internal micro-logic executed by an individual department staff reviewer:

1. **Prerequisite Gate Introspection:** The system first evaluates whether all upstream prerequisite gates have been satisfied. If Gate 2 is attempted while Gate 1 is incomplete, the request is immediately rejected with HTTP `400 Bad Request`.
2. **Physical Asset Inspection:** Staff checks institutional physical inventory (library books, hostel room equipment, sports kits, lab microcontrollers/oscilloscopes).
3. **Liability Branching:**
   - **Liability Detected:** Staff inputs the unpaid fine in INR (`₹ > 0.00`) and explanatory remarks, selecting `REJECTED`. The system persists the liability in `DS-4`, clears any existing signature, sets the overall clearance status in `DS-3` to `REJECTED`, and logs the rejection in `DS-6`.
   - **All Clear:** Staff sets dues to `₹0.00` and selects `APPROVED`. The system computes a cryptographic HMAC-SHA256 seal (`SIG-v1:<DEPT>:<HASH>`) using the server secret key, staff identity, department code, request ID, and timestamp. The digital seal is attached to `DS-4`, and the downstream gating evaluation engine is triggered.

4. Grievance Redressal: Decision Table 2 & Decision Tree 3

Decision Table 2: Priority SLA Deadline & Escalation Matrix

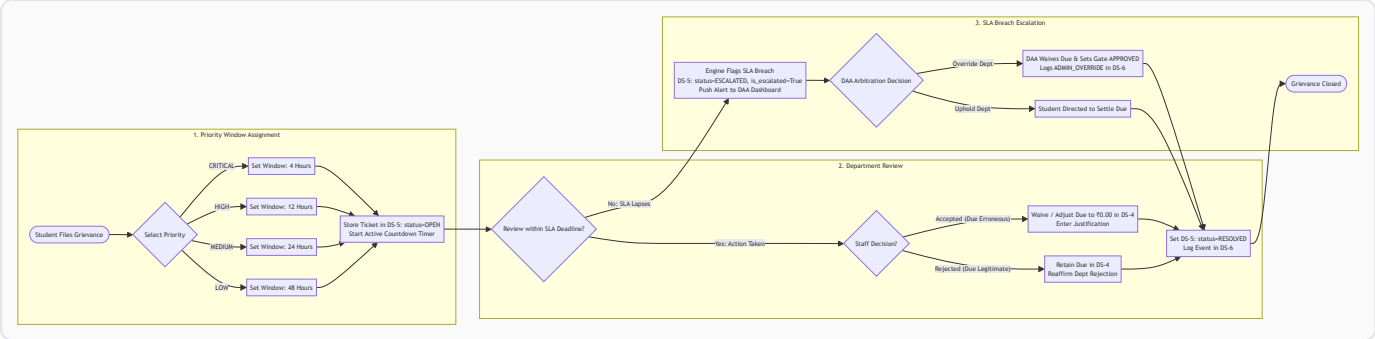
This decision table defines the dynamic Service Level Agreement (SLA) windows and automated escalation rules enforced by `Process 4`:

Rule ID	Priority	Allowed SLA Window	Elapsed Time (t)	Reviewer Action	Enforced System Action & Ticket Mutation
R-201	`CRITICAL`	**4 Hours**	$t \le$ 4 Hours	Pending review	Maintain active countdown timer (`status = OPEN`, `is_escalated = False`).
R-202	`CRITICAL`	**4 Hours**	**$t >$ 4 Hours**	None taken	**TRIGGER AUTO-ESCALATION:** Flag ticket for DAA; log breach; set `status = ESCALATED`, `is_escalated = True`.
R-203	`HIGH`	**12 Hours**	$t \le$ 12 Hours	Pending review	Maintain active countdown timer (`status = OPEN`, `is_escalated = False`).
R-204	`HIGH`	**12 Hours**	**$t >$ 12 Hours**	None taken	**TRIGGER AUTO-ESCALATION:** Flag ticket for DAA; log breach; set `status = ESCALATED`, `is_escalated = True`.
R-205	`MEDIUM`	**24 Hours**	$t \le$ 24 Hours	Pending review	Maintain active countdown timer (`status = OPEN`, `is_escalated = False`).
R-206	`MEDIUM`	**24 Hours**	**$t >$ 24 Hours**	None taken	**TRIGGER AUTO-ESCALATION:** Flag ticket for DAA; log breach; set `status = ESCALATED`, `is_escalated = True`.
R-207	`LOW`	**48 Hours**	$t \le$ 48 Hours	Pending review	Maintain active countdown timer (`status = OPEN`, `is_escalated = False`).
R-208	`LOW`	**48 Hours**	**$t >$ 48 Hours**	None taken	**TRIGGER AUTO-ESCALATION:** Flag ticket for DAA; log breach; set `status = ESCALATED`, `is_escalated = True`.
R-209	Any	Any	Any	Staff/DAA registers resolution	Set `status = RESOLVED`, record `staff_response`, zero or adjust INR dues in `DS-4`, set `resolved_at = Now`.

Decision Table 2 Explanation (Dynamic SLA Timers & Rules)

1. **Deterministic SLA Calculation:** Upon grievance filing, the engine computes an immutable deadline: $$\text{SLA Deadline} = \text{Created Timestamp} + \text{SLA Window}(\text{Priority})$$
   - `CRITICAL` (Immediate degree hold / convocation emergency): **4 Hours**
   - `HIGH` (Disputed fee / scholarship block): **12 Hours**
   - `MEDIUM` (Hostel mess bill / sports equipment dispute): **24 Hours**
   - `LOW` (General documentation inquiry): **48 Hours**
2. **Active Countdown Monitoring (Rules R-201, R-203, R-205, R-207):** While the elapsed time t remains within the allowable window, the ticket remains in `OPEN` status, displaying a live countdown badge in the reviewing staff member's queue.
3. **Automated SLA Breach Escalation (Rules R-202, R-204, R-206, R-208):** If the deadline lapses without staff action ($t > \text{SLA Window}$), the background engine automatically mutates the ticket status to `ESCALATED`, sets `is_escalated = True`, logs an `SLA_BREACH_ESCALATED` event in `DS-6`, and posts an urgent notification banner directly to the Dean Academic Affairs dashboard.
4. **Resolution Settlement (Rule R-209):** When an authorized staff official or the DAA registers a written decision, the ticket status updates to `RESOLVED`, the timestamp `resolved_at` is fixed, any disputed liability in `DS-4` is adjusted or waived, and the clearance gating engine re-evaluates student eligibility.

Decision Tree 3: Grievance Arbitration & Escalation



Decision Tree 3 Explanation

Decision Tree 3 visually depicts the three phases of grievance lifecycle management:

- **Phase 1 (Priority Classification):** The student submits a dispute ticket linked to an active clearance request and department. The system determines the SLA duration based on priority and persists the record in `DS-5`.
- **Phase 2 (Timely Staff Review):** If staff resolves the ticket before the SLA expires:
  - *Dispute Accepted:* Staff reduces the liability in `DS-4` to `₹0.00`, provides justification, and updates clearance eligibility.
  - *Dispute Rejected:* Staff reaffirms the legitimacy of the fine and provides policy references. The due is retained.
  - In both outcomes, the ticket moves to `RESOLVED` and is logged in `DS-6`.
- **Phase 3 (Breach & Executive Intervention):** If staff fails to act within the SLA window, the engine flags a breach, mutates the ticket to `ESCALATED`, and surfaces the dispute on the DAA executive dashboard. The DAA can either issue an executive override or direct the student to settle the dues.

---

5. Role-Based Access Control: Decision Table 3 & Decision Tree 4

Decision Table 3: RBAC Authorization Matrix

This decision table defines the role-based access permissions enforced by the API Gateway across all system routes:

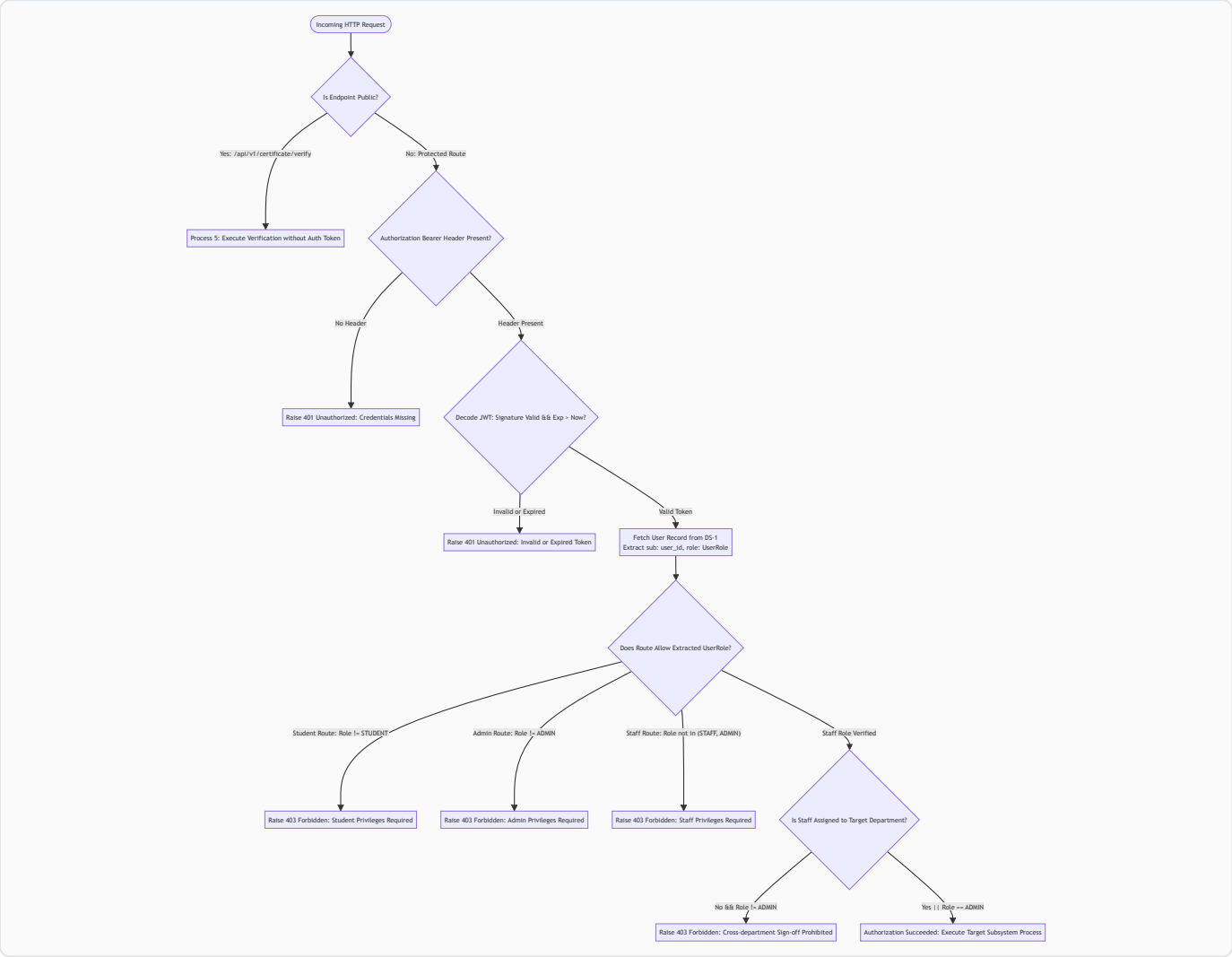
Action / Operation	API Route Endpoint	`STUDENT`	`STAFF` (Own Dept)	`STAFF` (Other Dept)	`ADMIN` (DAA)	`PUBLIC`	Enforced Breach Error
Apply for Clearance	`POST /api/v1/clearance/apply`	**ALLOW**	DENY	DENY	DENY	DENY	`403 Forbidden`
View My Pipeline	`GET /api/v1/clearance/my-requests`	**ALLOW**	DENY	DENY	DENY	DENY	`401 / 403`
View Staff Queue	`GET /api/v1/clearance/staff/queue`	DENY	**ALLOW**	DENY	**ALLOW**	DENY	`403 Forbidden`
Sign Department Gate	`POST /api/v1/clearance/staff/decision/{id}`	DENY	**ALLOW**	DENY	**ALLOW**	DENY	`403 Forbidden`

Action / Operation	API Route Endpoint	`STUDENT`	`STAFF` (Own Dept)	`STAFF` (Other Dept)	`ADMIN` (DAA)	`PUBLIC`	Enforced Breach Error
File Grievance Ticket	`POST /api/v1/grievance`	**ALLOW**	DENY	DENY	DENY	DENY	`403 Forbidden`
Resolve Grievance	`POST /api/v1/grievance/{id}/resolve`	DENY	**ALLOW**	DENY	**ALLOW**	DENY	`403 Forbidden`
Trigger SLA Scan	`POST /api/v1/grievance/trigger-sla-check`	DENY	**ALLOW**	**ALLOW**	**ALLOW**	DENY	`403 Forbidden`
View Campus Analytics	`GET /api/v1/admin/analytics`	DENY	**ALLOW**	**ALLOW**	**ALLOW**	DENY	`403 Forbidden`
View System Audit Logs	`GET /api/v1/admin/audit-logs`	DENY	DENY	DENY	**ALLOW**	DENY	`403 Forbidden`
Execute Admin Override	`POST /api/v1/admin/clearance/{id}/override`	DENY	DENY	DENY	**ALLOW**	DENY	`403 Forbidden`
Download PDF Cert	`GET /api/v1/certificate/download/{id}`	**ALLOW**	**ALLOW**	**ALLOW**	**ALLOW**	DENY	`401 Unauthorized`
Public Verification	`GET /api/v1/certificate/verify`	**ALLOW**	**ALLOW**	**ALLOW**	**ALLOW**	**ALLOW**	Public Access

Decision Table 3 Explanation (Security Scopes & Gate Enforcement)

1. **Student Least Privilege:** Students are strictly restricted to submitting clearance applications, reviewing their own pipeline progress, submitting grievance appeals, and downloading their finalized PDF certificate. Any attempt to access staff queues or administrative endpoints is blocked with HTTP `403 Forbidden`.
2. **Departmental Tenant Isolation (`STAFF Own` vs `STAFF Other`):** Positional staff members are cryptographically bound to their designated facility (`department_id`). A Librarian can sign off only Library clearances; attempts to inspect or approve Hostel or Lab records are blocked with HTTP `403 Forbidden: Cross-department Sign-off Prohibited`.
3. **Executive Scope (`ADMIN` / DAA):** The DAA possesses complete operational visibility, including campus-wide analytical dashboards, append-only system audit trails, and executive override endpoints (`POST /api/v1/admin/clearance/{id}/override`).
4. **Tokenless Public Access:** The certificate verification endpoint (`GET /api/v1/certificate/verify`) requires zero authentication tokens, allowing external employers and universities to independently verify credentials using Certificate IDs or SHA-256 hash digests.

Decision Tree 4: API Gateway Authentication & Authorization



Decision Tree 4 Explanation

Decision Tree 4 models the deterministic security decision pipeline applied to every inbound HTTP request by the API Gateway:

1. **Public Route Evaluation:** Checks if the target URL is the tokenless verification endpoint (`/api/v1/certificate/verify`). If yes, the request bypasses token verification and executes directly.
2. **Header & Token Introspection:** For all protected routes, verifies that the `Authorization: Bearer <token>` header exists. If absent, halts with HTTP `401 Unauthorized: Credentials Missing`.
3. **Cryptographic Validation:** Decodes the JWT, verifies the HMAC-SHA256 signature against the server secret key, and ensures `exp > current_timestamp`. Expired or tampered tokens return HTTP `401 Unauthorized: Invalid or Expired Token`.
4. **Role Authority Check:** Compares the token's `role` claim against the route's declared role requirements (`STUDENT`, `STAFF`, `ADMIN`). Mismatched roles return HTTP `403 Forbidden`.
5. **Departmental Scope Validation:** For staff actions (reviewing clearance or resolving grievances), verifies that the staff member's `department_id` matches the target record. Cross-department actions are blocked with HTTP `403 Forbidden`, while DAA administrators bypass this restriction. Once all gates pass, request execution proceeds.